

SEGURIDAD EN MEDIOS DE PAGO DIGITALES

Tema: Ciberseguridad en el Comercio Electrónico, Dinero Digital, Micropagos, Tarjetas de Crédito y Cheques Electrónicos.



UNIVERSIDAD DE GRANADA

Autores:

Fernando Castilla Roperio

Álvaro García Zafra

Jorge López Molina

SPSI 2024/2025

Índice

1. INTRODUCCIÓN AL DINERO DIGITAL

- 1.1 Panorama de Riesgos y Amenazas
- 1.2 Arquitectura de Defensa y Medidas Esenciales

2. MICROPAGOS: EL DESAFÍO DEL VOLUMEN

- 2.1 Desafíos Específicos
- 2.2 Soluciones Tecnológicas Aplicadas

3. CHEQUES ELECTRÓNICOS (E-CHECKS)

- 3.1 Vectores de Ataque
- 3.2 Protocolos de Seguridad

4. TARJETAS DE CRÉDITO: EVOLUCIÓN Y ESTÁNDARES

- 4.1 De la Banda Magnética al Chip EMV
- 4.2 El Estándar Global: PCI DSS
- 4.3 Seguridad en Comercio Electrónico (Card Not Present)

5. REFERENCIAS Y BIBLIOGRAFÍA

1. INTRODUCCIÓN AL DINERO DIGITAL

En el ecosistema financiero actual, la ciberseguridad no es una opción, sino un pilar fundamental. Su objetivo es garantizar la **triada CIA**: Confidencialidad, Integridad y Disponibilidad de las transacciones y activos digitales, sumando además un cuarto pilar esencial en transacciones financieras: el No Repudio. La digitalización del dinero introduce vectores de ataque sofisticados que requieren defensas en profundidad.

1.1 Panorama de Riesgos y Amenazas

Los riesgos asociados al dinero digital se clasifican en cuatro categorías críticas:

A. Ingeniería Social y Software Malicioso

- **Phishing Avanzado y Spear Phishing:** Los ciberdelincuentes suplantan la identidad de entidades legítimas (bancos, exchanges) mediante correos o webs fraudulentas.
- **SIM Swapping:** Técnica donde el atacante duplica la tarjeta SIM de la víctima para interceptar los códigos SMS de doble factor.
- **Malware bancario y Keyloggers:** Uso de troyanos diseñados para infectar dispositivos finales (endpoints), permitiendo la captura de credenciales y la inyección de formularios web falsos.

B. Vulnerabilidades Sistémicas

- **Fallas en Exchanges Centralizados:** Las plataformas de intercambio son objetivos de alto valor. Las brechas en sus "billeteras calientes" (hot wallets) o proveedores externos han derivado en pérdidas masivas.
- **Bugs en Contratos Inteligentes (Smart Contracts):** En el sector DeFi (Finanzas Descentralizadas), errores en el código inmutable de los contratos pueden ser explotados para llevarse los fondos sin posibilidad de reversión.

C. Factor Humano y Dispositivos

- **Gestión de Claves Privadas:** En criptografía asimétrica, la clave privada es el único acceso a los activos. Su pérdida o compromiso es irreversible.
- **Seguridad Móvil:** La ubicuidad de la banca móvil amplía la superficie de ataque. Un dispositivo comprometido es una puerta abierta directa a las cuentas bancarias del usuario.

D. Fraudes Financieros

- **Esquemas Ponzi Digitales:** Estafas de inversión que prometen retornos irreales basados en la captación de nuevos usuarios. Pueden sostenerse sobre tokens sin valor real.
- **Ransomware:** Secuestro de datos mediante cifrado, exigiendo rescates en criptomonedas para dificultar el rastreo de los fondos.

1.2 Arquitectura de Defensa y Medidas Esenciales

Principio Fundamental: La seguridad debe implementarse en capas, desde el usuario final hasta la infraestructura crítica.

Nivel de Usuario (Endpoint)

1. **Doble Factor de Autenticación (2FA):** La medida defensiva más crítica.
2. **Autenticación Multifactor (MFA):** Evolución del 2FA. Se recomienda el uso de aplicaciones autenticadoras (TOTP) o llaves de seguridad físicas (U2F/FIDO2) en lugar de SMS, vulnerables al SIM Swapping.
3. **Higiene de Credenciales:** Uso de contraseñas complejas que combinen diferentes tipos de caracteres y que no sean reutilizadas en diferentes plataformas. Para mayor seguridad se pueden utilizar gestores de contraseñas que generen claves robustas, únicas y complejas.
4. **Actualización Constante:** Parcheado riguroso de sistemas operativos y aplicaciones de *wallet* para cerrar brechas de seguridad conocidas.
5. **Protección contra Phishing:** Desconfiar de mensajes o correos que solicitan credenciales, además de no hacer clic en los enlaces o archivos adjuntos en dichos mensajes/correos.

Nivel de Infraestructura Bancaria

- **Cifrado de Extremo a Extremo:** Uso de protocolos SSL/TLS para asegurar que el tránsito de datos se realice a través de conexiones seguras y encriptadas.
- **Tecnología Blockchain/DLT:** Garantizar la inmutabilidad y transparencia mediante algoritmos criptográficos, haciendo extremadamente difícil la alteración de registros históricos.
- **Monitoreo Activo:** Implementación de IDS/IPS (Sistemas de Detección de Intrusiones) y UEBA (Análisis de Comportamiento de Usuarios) para detectar y bloquear actividades fraudulentas en tiempo real.

2. MICROPAGOS: EL DESAFÍO DEL VOLUMEN

Los micropagos presentan una paradoja de seguridad: el bajo valor individual de la transacción frente al alto volumen global. Robar 1€ mil veces es a menudo más efectivo y menos rastreable que robar 1.000€ de una vez.

2.1 Desafíos Específicos

- **Fricción vs. Seguridad:** El usuario no desea barreras (como contraseñas complejas) para pagos insignificantes (ej. 0,50€). Esto dificulta la implementación de controles estrictos, lo cual se contradice con la necesidad de implementar mecanismos de

autenticación (2FA).

- Aunque un ataque de este tipo en una sola cuenta no suponga una gran pérdida, se puede dar el caso de un ataque de este tipo a gran escala realizando esto en miles de cuentas al mismo tiempo.
- **Vulnerabilidad IoT:** Muchos micropagos provienen de dispositivos *Internet of Things* o *Wearables* con capacidades de procesamiento limitadas, lo que impide ejecutar cifrados robustos o parches de seguridad complejos.
- **Ataques Man-in-the-Middle (MitM):** En pagos *Contactless* (NFC), existe el riesgo de interceptación de señal entre el dispositivo y el terminal, para evitar esto se puede implementar el método de **Tokenización de credenciales**, para evitar que la información intercambiada en el pago no sea con la tarjeta real, sino con un token temporal el cuál expirará y no permitirá utilizarlo en otro momento.

2.2 Soluciones Tecnológicas Aplicadas

Para proteger el volumen sin sacrificar la velocidad, se emplean técnicas avanzadas:

Tecnología	Descripción y Beneficio
Tokenización	Sustitución de datos sensibles por un <i>token</i> temporal. Si es interceptado, el token es inútil fuera de su contexto original.
Autenticación Adaptativa	Análisis de riesgo contextual. Si el comportamiento es habitual, se aprueba sin fricción. Si es anómalo (ej. cambio de ubicación repentino), se exige SCA (Strong Customer Authentication).
Off-Chain (Fuera de Cadena)	Uso de canales privados (ej. Lightning Network) para procesar miles de transacciones sin saturar la red principal, registrando solo el saldo final. Mejora la privacidad y reduce costes.

3. CHEQUES ELECTRÓNICOS (E-CHECKS)

El *e-Check* consiste en una instrucción de pago digital que moderniza a los cheques tradicionales, permitiendo la transferencia de fondos de una cuenta a otra. Para ello, utiliza la red **SEPA (Zona Única de Pagos en Euros)**, que garantiza costes transaccionales bajos y una alta seguridad en toda la Unión Europea. Esto la hace vital en entornos **B2B** (empresa a empresa) y en comercios electrónicos, especialmente para la gestión de cobros recurrentes y

suscripciones.

3.1 Vectores de Ataque

- **Account Takeover (ATO):** El robo de credenciales permite a atacantes emitir cheques fraudulentos desde cuentas legítimas.
- **Manipulación de Archivos Batch:** Infiltración en redes corporativas para alterar los archivos de lotes de pagos antes de su envío al banco, desviando nóminas o pagos a proveedores.
- **Fraude de "Cheque Rebotado":** Aprovechamiento de los tiempos de compensación de los e-checks, los cuáles no se liquidan instantáneamente, pudiendo recibir bienes antes de que se confirme la falta de fondos.

3.2 Protocolos de Seguridad

- **Validación SEPA:** Consiste en la verificación automática del **IBAN** y su estado, además de comprobar la validez del **código BIC/SWIFT** de la entidad bancaria (identificador del banco) antes de procesar la orden.
- **Cumplimiento PCI DSS:** Aunque originado para tarjetas, sus estándares de cifrado y protección de datos se aplican para blindar la información bancaria. Se basa en doce requisitos clave distribuidos en seis dominios, que incluyen el uso de firewalls, cifrado de datos, software antivirus, control de acceso y políticas de seguridad, y define niveles de cumplimiento según el volumen de transacciones.
- **MFA(Autenticación Multifactorial) para Aprobación de Lotes:** consiste en requerir múltiples firmas digitales o aprobaciones para liberar archivos de pagos masivos, mitigando el riesgo de fraude interno.
- **IA para Detección de Fraude:** Algoritmos de Machine Learning que detectan patrones anómalos (cantidades inusuales, nuevos beneficiarios) en tiempo real.
 - Ejemplos de estos patrones pueden ser e-check de cantidades inusuales a nuevos destinatarios o transacciones que inicien desde ubicaciones sospechosas.
 -

4. TARJETAS DE CRÉDITO: EVOLUCIÓN Y ESTÁNDARES

La seguridad en tarjetas ha migrado de la protección física a la lógica y criptográfica.

4.1 De la Banda Magnética al Chip EMV

El estándar **EMV (Europay, Mastercard, Visa)** eliminó la clonación tradicional. A diferencia de la banda magnética (estática), el chip genera un proceso criptográfico único para cada transacción, en el caso de que un atacante capture los datos de una compra, no puede

replicarlos para una segunda operación, solucionando así el fraude por clonación física.

4.2 El Estándar Global: PCI DSS

Las entidades que procesan, almacenan o transmiten datos de tarjetas de crédito están obligadas a cumplir con el **Estándar de Seguridad de Datos para la Industria de Tarjetas de Pago (PCI DSS)**. El objetivo de esto es proteger los datos de los titulares de las tarjetas durante el proceso de la transacción. Sus pilares incluyen:

- Mantenimiento de una red segura (Firewalls, configuraciones robustas).
- Protección de datos del titular (Cifrado fuerte en tránsito y reposo).
- Gestión de vulnerabilidades y control de acceso estricto.

4.3 Seguridad en Comercio Electrónico

Los mayores riesgos de fraude actualmente se dan en las transacciones en las cuales la tarjeta no está físicamente presente, es decir, las compras por Internet.

Para ello se aplica el protocolo **3D Secure**:

1. **3D Secure 2.0:** En lugar de pedir siempre una contraseña estática utiliza el **Análisis de Riesgo** en tiempo real, evaluando datos como la ubicación, datos de otras compras... para validar las transacciones, permitiendo que las operaciones se aprueben automáticamente y activando **Autenticación Adaptativa** (huellas digitales o reconocimiento facial) cuando se detectan actividades inusuales.
2. **Tokenización Digital:** En billeteras móviles (Apple Pay, Google Pay), el número real de la tarjeta (PAN) nunca se almacena en el dispositivo ni se comparte con el comercio. Se usa un *token* específico del dispositivo.
3. **Tarjetas Virtuales de un solo uso:** Generación de números de tarjeta de un solo uso o con límites estrictos de tiempo/gasto, ideales para compras en sitios de confianza desconocida.

5. REFERENCIAS Y BIBLIOGRAFÍA

Para la elaboración de este informe técnico se han considerado los estándares y publicaciones de las siguientes entidades de referencia:

- **PCI Security Standards Council.** *Payment Card Industry Data Security Standard (PCI DSS)*. El estándar global para la seguridad de datos de tarjetas y cumplimiento normativo en pagos.

<https://www.pcisecuritystandards.org/standards/>

- **NIST (National Institute of Standards and Technology).** *Digital Identity Guidelines (Special Publication 800-63)*. Marco de referencia internacional para identidad digital, autenticación y ciclo de vida de credenciales.

<https://pages.nist.gov/800-63-3/>

- **ECB (European Central Bank).** *Report on a digital euro*. Informes oficiales sobre el diseño, privacidad, seguridad y funcionalidad de la moneda digital del banco central (CBDC) europeo.

https://www.ecb.europa.eu/pub/pdf/other/Report_on_a_digital_euro~4d7268b458.en.pdf

- **NACHA.** *ACH Security Framework*. Normas operativas y requisitos de seguridad de datos para la red de pagos ACH (base de los cheques electrónicos y transferencias directas).

<https://www.nacha.org/rules/supplementing-data-security-requirements>

- **ENISA (European Union Agency for Cybersecurity).** *Security of Mobile Payments and Digital Wallets*. Guías sobre amenazas, riesgos y controles de seguridad en el ecosistema de pagos móviles.

<https://www.enisa.europa.eu/sites/default/files/publications/WP2016%203-1%204%20Mobile%20Payments%20Security.pdf>